



# Network Security Guideline

Version: 2.0

Valid From Date: 19.08.2026

Last Review Date: 14.08.2026

**Notes:** This written rule uses gender-neutral and inclusive language. Whenever possible, the generic masculine is avoided and all employees of any gender identity (m/f/d) are addressed.

Content changes compared to the previous document version are highlighted in color.

# Content

|                                                            |    |
|------------------------------------------------------------|----|
| <b>1. Purpose, Objectives and Basis</b> .....              | 3  |
| 1.1. Purpose and Objectives .....                          | 3  |
| 1.2. Basis of this Guideline .....                         | 4  |
| <b>2. Functional Scope and Target Groups</b> .....         | 5  |
| 2.1. Functional scope of applicability .....               | 5  |
| 2.2. Target groups .....                                   | 5  |
| 2.3. Transition period .....                               | 6  |
| <b>3. Definitions</b> .....                                | 7  |
| 3.1. Requirements .....                                    | 7  |
| 3.2. Explanation of requirements and key definitions ..... | 8  |
| <b>4. Requirements</b> .....                               | 9  |
| 4.1. Requirements .....                                    | 9  |
| <b>5. Roles and Responsibilities</b> .....                 | 24 |
| 5.1. Creator .....                                         | 24 |
| 5.2. Guideline Owner .....                                 | 24 |
| <b>6. Appendix</b> .....                                   | 25 |
| 6.1. Contact Information .....                             | 25 |
| 6.2. Document History .....                                | 25 |
| 6.3. Related Written Rules .....                           | 25 |
| 6.4. Abbreviations .....                                   | 26 |

# 1. Purpose, Objectives and Basis

## 1.1. Purpose and Objectives

The Network Security Guideline (hereinafter “Guideline”) establishes control requirements for DBAG and/or adopting Legal Entities within DBG (refers only to Legal Entities that have ratified the Guideline at hand) and provides criteria for fulfilling the control requirements.

The purpose of the Guideline is to effectuate the below listed Minimum Requirements, stipulated in the ICT Risk Management Policy (structured into Core Functions), acting as objectives to the Guideline and the control requirements at hand:

| Core Function   | Minimum Requirement                                                                                                                                                                                                                                                                                                                                                              | ICT Risk Management Policy chapter |
|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|
| <b>Govern</b>   | 2. Allocate roles and responsibilities as detailed in chapter 5 in the ICT Risk Management Policy.                                                                                                                                                                                                                                                                               | 4.1                                |
| <b>Govern</b>   | 6. Have in place a mechanism to define and document responsibilities for implementing control requirements both within and outside IT and IS (e.g. HR). This can be documented e.g. as part of the <b>ICT Control Framework (former Mandatory Control Framework (MCF))</b> .                                                                                                     | 4.1                                |
| <b>Identify</b> | <b>2.</b> Identify and record assets (e.g. data, hardware, software, systems, facilities, services, people) <b>including respective interdependencies</b> and classify these assets with their relative importance to organizational objectives (including security objectives) and the organisation's risk strategy.                                                            | 4.2                                |
| <b>Identify</b> | <b>4.</b> Establish an ICT risk management process and perform ICT risk assessment on a regular basis and in the event of major changes, considering threats and vulnerabilities covering different IT assets (e.g. applications) and Non-IT assets (e.g. buildings, rooms) in a consistent way taking into consideration asset-specific differences in the assessment approach. | 4.2                                |
| <b>Protect</b>  | 1. Design and implement ICT risk management control requirements to achieve the protection goals and integrating them to the ICT <b>Written Rules</b> framework. These control requirements are including but not limited to ICT operations and physical and environmental security, network and                                                                                 | 4.3                                |

|                |                                                                                                                                                                                                                                                                                                                                                                                                            |     |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----|
|                | infrastructure management, encryption and cryptographic controls, identity management and logical/physical access control, software development, change and project management, threat management, patch and vulnerability management, human resources, and third-party management, AI, IDP & NCLC <sup>1</sup> , data management and other controls addressing poor administration and human error risks. |     |
| <b>Protect</b> | 3. Put in place information transfer rules, procedures, or agreements for all types of transfer facilities within the organisation and between the organisation and other parties.                                                                                                                                                                                                                         | 4.3 |
| <b>Detect</b>  | 1. Define, implement, monitor, and regularly test detection processes and mechanisms to promptly detect anomalous activities including network performance issues and ICT-related incidents, and identify potential material single points of failure.                                                                                                                                                     | 4.4 |

Table 1: Minimum Requirements

Note: The full list of Core Functions and Minimum Requirements is stipulated in the ICT Risk Management Policy.

## 1.2. Basis of this Guideline

The basis for this Guideline is the thematically linked ICT Risk Management Policy.

---

<sup>1</sup> IDP refers to Individual Data Processing, and NCLC refers to No-Code/Low-Code solutions.

## 2. Functional Scope and Target Groups

### 2.1. Functional scope of applicability

|               |                                                                                                                                                    |
|---------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Entity</b> | DBAG and/or adopting LE within DBG                                                                                                                 |
| <b>Area</b>   | DBAG CIO / COO Division; Chief Risk Officer Area; or any other area that owns Network Security; or any other area that owns Network Security topic |

Table 2: Scope

### 2.2. Target groups

Within the scope of the current Network Security Guideline below is addressed the list of applicable target groups and operation areas<sup>2</sup>:

| <b>Target group</b>        | <b>Key message</b>                                                                                                                                                        |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ICT Risk Oversight         | To oversee, review and validate the information risk management, and enforcement of network security policies and ensure alignment with broader cybersecurity strategies. |
| ICT Operational Management | To implement and manage network security measures.                                                                                                                        |
| Business Management        | To implement and manage Network Security solutions and controls and monitor for potential network issues ensuring the security and integrity of ICT systems and data.     |

Table 3: Target groups

---

<sup>2</sup> For LE Guidelines adoption process the target groups should be adjusted according to organizational structure of the LE.

## 2.3. Transition period

The grace period for new requirements commences from the “valid from” date stated on the cover page. The compliance dates for control requirements defined in this version of the Guideline are defined as follows:

- For unchanged control requirements and new DORA requirements the compliance date equals the “valid from” date.
- For new and changed control requirements that are more stringent than before and are not subject to DORA, the compliance date is generally 90 calendar days after the “valid from” date unless otherwise stated in brackets after the control requirements. These control requirements are marked with ●.
- For Legal Entities that have not previously approved the IT-related requirements and are therefore addressing these requirements for the first time, a grace period of 90 days may be granted at the discretion of the Legal Entity. DORA requirements are exempt from this grace period.

For a **compliance date** exceeding 180 calendar days implementation timeline, a Board approval is required.

## 3. Definitions

### 3.1. Requirements

#### Control requirement

The control requirements define the organizational, process or technical controls to be implemented by the control owner to achieve compliance with this Guideline.

#### Criteria

Criteria define the measures that 'must' or 'should' be taken to fulfill the control requirement.

#### Level of obligation

With respect to requirements and criteria, the following terms are used to define the level of obligation, provided for the implementation of a particular requirement or criteria:

- **“must”**: Mandatory control requirements / criteria derived directly from law, regulations, or internal specifications that the legal entity must comply with. Incompliance could result in consequences with external regulators and Internal Audit.
- **“should”**: Non-mandatory control requirements / criteria derived from best-practice frameworks or equivalent sources that the legal entity does not have to necessarily comply with. Under specific circumstances there may exist valid reasons to ignore a particular control requirement, but the full implications must be understood and carefully weighed.

Independent of the level of obligation of a given requirement or criteria, it is allowed to deviate from single requirements or criteria in individual cases. However, a control requirement deviation always requires the conduction of a risk assessment and risk management including adequate risk acceptance and/or mitigation.

Any deviation from the Guideline denotes an exemption. The respective Information Owner makes decisions on such exemptions. Information Owners can only decide on risks with impact exclusively in their area of responsibility.

#### Responsibilities

The responsibility for fulfilling control requirements may be distributed across the organization, e.g., multiple Sections, Units, or Departments. In some cases, one Unit may be responsible for both the design and implementation of measures. In other cases, one Unit may be responsible for the design of measures, and another Unit may be responsible for the implementation of the measures. In addition, multiple Units may be responsible to collectively fulfill one requirement.

The precise responsibilities are to be defined in the underlying Procedure documents (e.g. via RACI matrices).

The ICS, among its various functionalities, registers Process Operators (PO) and Risk Representatives (RRs) mapped to the corresponding processes, controls, and risks which the RRs and/or POs are responsible for managing on behalf of the part of the organization that utilize their services (e.g. Asset Owners). For more information on ICS, please refer to the DBG ICS Guideline.

### 3.2. Explanation of requirements and key definitions

Control requirements are defined in a standardized format and are structured into the following components:

| <Specify ID:<br>xx (version<br>x)> | <Name of control requirement (e.g. Access to production data)>                                                                                                                                                                                                                                                                                                                                        |
|------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1                                  | <Description of the control requirement>                                                                                                                                                                                                                                                                                                                                                              |
| 1.1<br>1.1.1                       | <Lists the criteria applying to the control requirement><br><br><Lists the sub-criteria applying to the control requirement><br><br><b>Asset-Types:</b> <Lists asset types applicable to the control requirement><br><br><b>Key references:</b> <Lists key regulatory references and industry best practice requirements affecting this control requirement (e.g., ISO/IEC 27001:2022 A.5.10, A.8.1)> |

The terms in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

## 4. Requirements

### 4.1. Requirements

| ID: 1<br>(version 2.0)     | Network and cloud architecture                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1<br>DOR.ICT.NWS.ACH.001   | <b>It must be ensured that networks are designed in line with the established IT security requirements.</b>                                                                                                                                                                                                                                                                                                                                                                           |
| 1.1<br>DOR.ICT.NWS.ACH.002 | <p>Relevant established requirements as well as best practices or standards within the industry must be taken into account when designing networks.</p> <p><b>Asset-Types:</b> Information, Business Process, Tool, Certificate, Operating System, Cloud PaaS, Container, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1f</p>                                                                                                                                   |
| 1.2<br>DOR.ICT.NWS.ACH.003 | <p>The network architecture and the network security design must be reviewed annually to identify potential vulnerabilities.</p> <p><b>Asset-Types:</b> Information, Business Process, Tool, Certificate, Operating System, Cloud PaaS, Container, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1i</p>                                                                                                                                                          |
| 1.3<br>DOR.ICT.NWS.ACH.004 | <p>The network topologies with <b>all</b> network connections and data flows must be documented, including but not limited to the clear specification of relevant elements like network security zones, network segments and their classification based on the assigned IT applications in the respective segment.</p> <p><b>Asset-Types:</b> Information, Business Process, Tool, Certificate, Cloud PaaS, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1b</p> |
| 1.4<br>DOR.ICT.NWS.ACH.005 | <p>The documentation on network topology must be reviewed and updated after major network changes or at least annually.</p> <p><b>Asset-Types:</b> Information, Business Process, Tool, Certificate, Operating System, Cloud PaaS, Container, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                   |
| 1.5<br>DOR.ICT.NWS.ACH.006 | <p>Architecture guidance and best practices for the use of cloud services must be established to get the right balance between usage of cloud native services and avoidance of lock-in by providing the required interoperability and portability where needed.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, SaaS, Cloud Appliance, Operating System, Cloud PaaS, Container, Network Connection</p> <p><b>Key References:</b> /</p>   |

| ID: 2<br>(version 2.0)          | Network configuration                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>2</b><br>DOR.ICT.NWS.CON.001 | <b>It must be ensured through appropriate network configuration that all network and infrastructure components are securely configured and hardened.</b>                                                                                                                                                                                                                                                                                                                                                                                 |
| 2.1<br>DOR.ICT.NWS.CON.002      | <p>Secure configuration and hardening baselines for all network and infrastructure components must be defined, documented, implemented and, for components in the Red and Yellow Segregation Areas regularly be reviewed in line with the ICT Operations Guideline.</p> <p><b>Asset-Types:</b> Information, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1k</p> |
| 2.1.1<br>DOR.ICT.NWS.CON.003    | <p>All instructions from vendors as well as best practices and standards within the industry, that can serve as a robust benchmark, must be followed.</p> <p><b>Asset-Types:</b> Information, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1k</p>                                                                                                               |
| 2.2<br>DOR.ICT.NWS.CON.004      | <p>Hardening baselines must be implemented and verified before using a new or changed infrastructure component in the Red Segregation Area in line with the ICT Operations Guideline.</p> <p><b>Asset-Types:</b> Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Storage, Server &amp; Host Hardware</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.20</p>                                                                                                    |
| 2.3<br>DOR.ICT.NWS.CON.005      | <p>Procedures must be in place to limit, lock and terminate ICT systems and remote sessions after a specific period of inactivity.</p> <p><b>Asset-Types:</b> Business Process, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1l</p>                                                                                                                                         |
| 2.4<br>DOR.ICT.NWS.CON.006      | <p>Configuration files of security-relevant network components must be secured against tampering (running configuration files and start-up configuration files).</p> <p><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                |

| ID: 3<br>(version 2.0)       | Network services                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 3<br>DOR.ICT.NWS.SER.001     | <b>It must be ensured that network services are managed, and security features are documented in a way that ensures consistent and secure service delivery.</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| 3.1<br>DOR.ICT.NWS.SER.002   | <p>A regular process must be defined and implemented to identify, specify, document, and monitor IT and information security measures and features (typically in a service catalogue, or Asset Security Documentation (ASD)), service levels and management requirements of all network services with their defined scope and applicability.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Network Connection, Supplier</p> <p><b>Key References:</b> DORA RTS RMF A.13.1m.i)</p> |
| 3.1.1<br>DOR.ICT.NWS.SER.003 | <p>It must be specified whether the services are provided by an ICT third-party service provider or an internal service provider.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Network Connection, Supplier</p> <p><b>Key References:</b> DORA RTS RMF A.13.1m.ii)</p>                                                                                                                                                                                                           |
| 3.2<br>DOR.ICT.NWS.SER.004   | <p>A regular process for managing network services must be defined as part of the network operational documentation and include responsibilities, standard and emergency operation procedures, defined implementation rules and related communication as part of change management process.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.21</p>                                                                  |
| 3.3<br>DOR.ICT.NWS.SER.005   | <p>The scope of documentation must be in accordance with the asset specifications documented in an asset inventory.</p> <p><b>Asset-Types:</b> Information, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.21</p>                                                                                                                                                                                                                                                                                                                                                                                                    |
| 3.4<br>DOR.ICT.NWS.SER.006   | <p><b>Each network segment must have a defined list of allowed access protocols.</b></p> <p><b>Asset-Types:</b> Information, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.21</p>                                                                                                                                                                                                                                                                                                                                                                                                                                   |

| ID: 4<br>(version 2.0)   | Access to network-connected IT Assets                                                                                                  |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| 4<br>DOR.ICT.NWS.ACC.001 | <b>It must be ensured that access to network-connected IT Assets, especially networks and network services, are controlled through</b> |

|                            | <b>stringent access controls and authentication mechanisms to ensure only authorized entities can connect and access the resources.</b>                                                                                                                                                                                                                                                                                                                                                                                                            |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 4.1<br>DOR.ICT.NWS.ACC.002 | Secure access to IT Assets from devices used for remote work must be ensured.<br><br><b>Asset-Types:</b> Information, End User Device, Mobile Device<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.6.7                                                                                                                                                                                                                                                                                                                                     |
| 4.2<br>DOR.ICT.NWS.ACC.003 | Network access controls must be identified and implemented to prevent and detect network connections by unauthorized devices or ICT systems, including endpoints not meeting the defined security requirements.<br><br><b>Asset-Types:</b> Information, Business Process, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection<br><b>Key References:</b> DORA RTS RMF A.13.1d                                                                                                  |
| 4.3<br>DOR.ICT.NWS.ACC.004 | The network connection between external and internal ICT Systems must only be established after authentication and must be encrypted.<br><br><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15 |
| 4.4<br>DOR.ICT.NWS.ACC.005 | All IT Assets connecting to the corporate network of the legal entity's internal wireless infrastructure must be authenticated.<br><br><b>Asset-Types:</b> Information, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15                                                                                                                                                                                                                |
| 4.5<br>DOR.ICT.NWS.ACC.006 | Access to internal legal entity ICT systems and networks from external/non-legal entity networks must only be possible after two-factor-authentication via approved legal entity environments.<br><br><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15                                                                                                                                                                         |
| 4.6<br>DOR.ICT.NWS.ACC.007 | All ICT Systems, including IT Applications, and users must only have access to networks and network services that they have been specifically authorized to use based on the need-to-know principle.<br><br><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Storage, Network Connection, Supplier<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15                           |

| ID: 5<br>(version 2.0)              | Protection of network connections and data in transit                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>5</b><br>DOR.ICT.NWS.CON.001     | <b>Network connections, including data in transit, must be protected in a way that preserves their integrity and ensures confidentiality.</b>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| <b>5.1</b><br>DOR.ICT.NWS.CON.002   | <p>Network connections, with the respective communication protocols used, as well as data in transit passing over all types of networks must be encrypted to preserve confidentiality, integrity, availability, and authenticity in line with the Encryption and Key Management Guideline by using standardized, secure cryptographic protocols (e.g., TLS) with legal entity approved cryptographic measures and a secure configuration to prevent man-in-the-middle attacks. The following must be ensured:</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1e</p> |
| <b>5.1.1</b><br>DOR.ICT.NWS.CON.003 | <p>Procedures must be established to assess compliance with the requirements on the protection of data during network transmission.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.14.1a</p>                                                                                                                                                                                                                                                                                                                                                                           |
| <b>5.1.2</b><br>DOR.ICT.NWS.CON.004 | <p>Network traffic between internal networks and the Internet as well as other external connections must be secured.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, End User Device, Mobile Device, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1g</p>                                                                                                                                                                                                                                                                                                                                                                                          |

| ID: 6<br>(version 2.0)            | Separation of environments                                                                                                                                                                                                 |
|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>6</b><br>DOR.ICT.NWS.SEP.001   | <b>Dedicated environments must be provided in accordance with their intended use.</b>                                                                                                                                      |
| <b>6.1</b><br>DOR.ICT.NWS.SEP.002 | <p>Red, Yellow, Blue and Green segregation areas must be segregated at least logically.</p> <p><b>Asset-Types:</b> Business Process, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.31</p> |
| <b>6.2</b><br>DOR.ICT.NWS.SEP.003 | <p>A physically separate network test lab must be provided for testing and acceptance testing of on-premises network services.</p>                                                                                         |

|  |                                                                                                                                                                                                                                                 |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.31</p> |
|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

| ID: 7<br>(version 2.0)       | Segregation in networks                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 7<br>DOR.ICT.NWS.SEG.001     | It must be ensured that networks are segregated appropriately.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 7.1<br>DOR.ICT.NWS.SEG.002   | <p>Groups of network connected IT Assets <b>must</b> be segmented and segregated into different types of network security zones according to their purpose:</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                       |
| 7.1.1<br>DOR.ICT.NWS.SEG.003 | <p>The network security zones types must at least be logically segregated from each other.</p> <p><b>Asset-Types:</b> Information, Business Process</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| 7.1.2<br>DOR.ICT.NWS.SEG.004 | <p>Within the network security zone types the network-connected IT Assets <b>must</b> be segregated on a risk-based approach.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                     |
| 7.1.3<br>DOR.ICT.NWS.SEG.005 | <p>Within the Internet and Partner network security zone types, the network-connected IT Assets <b>must</b> be assigned to their own DMZ on a risk-based approach.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                |
| 7.2<br>DOR.ICT.NWS.SEG.006   | <p>The following must be considered in the risk-based approach for segregation:</p> <ul style="list-style-type: none"> <li>- The criticality or importance of the function those ICT Systems, including networks, support</li> <li>- The established classification</li> <li>- The overall risk profile of IT Assets using those ICT Systems, including networks</li> </ul> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Container, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1ai),ii),iii)</p> |
| 7.3<br>DOR.ICT.NWS.SEG.007   | <p>All network-connected IT Assets must be assigned to a network security zone that corresponds to their use case.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |

|                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              | <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                      |
| 7.4<br>DOR.ICT.NWS.SEG.008   | <p>The perimeter of each network security zone must be defined.</p> <p><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                     |
| 7.5<br>DOR.ICT.NWS.SEG.009   | <p>Connections from external networks must be terminated in designated DMZ and must be protected by two-stage firewall (inner and outer) which are from different vendors.</p> <p><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                      |
| 7.5.1<br>DOR.ICT.NWS.SEG.010 | <p>For SaaS, equivalent protection level should be applied.</p> <p><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                                     |
| 7.5.2<br>DOR.ICT.NWS.SEG.011 | <p>For IaaS and PaaS where network controls are harmonized with internal networks, PaaS and IaaS can be treated as internal networks. Otherwise, the same protections for external networks must be applied.</p> <p><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                    |
| 7.6<br>DOR.ICT.NWS.SEG.012   | <p>If a DMZ is not used, whether due to business model limitations or other valid reasons, a justification must be documented and an equivalent solution with an adequate verified level of protection must be implemented.</p> <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p> |
| 7.7<br>DOR.ICT.NWS.SEG.013   | <p>For the administration of IT Assets, a separate and dedicated network must be used.</p> <p><b>Asset-Types:</b> Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> DORA RTS RMF A.13.1c</p>                                                                                                                                |
| 7.8<br>DOR.ICT.NWS.SEG.014   | <p>Automated mechanisms must be in place and the network connection infrastructure must be designed in a way that allows to temporarily isolate, where necessary, subnetworks, network components and network connected IT Assets instantaneously.</p>                                                                                                                                                                                                                                                                                                  |

|  |                                                                                                                                                                                                                                                                                                                                                                                          |
|--|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  | <b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server & Host Hardware, Network Connection<br><b>Key References:</b> DORA RTS RMF A.13.1j |
|--|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

| ID: 8<br>(version 2.0)     | Firewalls and connection filters                                                                                                                                                                                                                                                                                                             |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8<br>DOR.ICT.NWS.FWF.001   | <b>Firewalls and connection filters must be implemented and managed to ensure reliable and strict control of data traffic between networks on an ongoing basis.</b>                                                                                                                                                                          |
| 8.1<br>DOR.ICT.NWS.FWF.002 | Firewall configurations must prevent any unauthorized connections between network security zones.<br><b>Asset-Types:</b> Business Process, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                         |
| 8.2<br>DOR.ICT.NWS.FWF.003 | Firewall rules must be implemented according to defined criteria for network connectivity.<br><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server & Host Hardware, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                          |
| 8.3<br>DOR.ICT.NWS.FWF.004 | Implementation and removal of firewall rules must follow defined procedures <sup>3</sup> , if possible, with an automatic workflow.<br><b>Asset-Types:</b> Business Process, Hardware Appliance, Cloud Appliance, Cloud PaaS, Storage, Server & Host Hardware, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22 |
| 8.4<br>DOR.ICT.NWS.FWF.005 | If provisioning is done manually, additional controls (four-eyes-principle) must be established.<br><b>Asset-Types:</b> Business Process<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                          |
| 8.5<br>DOR.ICT.NWS.FWF.006 | Roles, responsibilities and steps for the specification, implementation, approval, change and review of firewall rules and connection filters must be identified in defined procedures <sup>4</sup> .<br><b>Asset-Types:</b> Business Process<br><b>Key References:</b> DORA RTS RMF A.13.,.1h                                               |
| 8.6<br>DOR.ICT.NWS.FWF.007 | Firewall rules and connection filters must be recertified regularly and adhere to all of the following:                                                                                                                                                                                                                                      |

<sup>3</sup> As defined in the firewall rule management procedures.

|                              |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                              | <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware</p> <p><b>Key References:</b> DORA RTS RMF A.13.1h</p>                                                                                                                                                                                |
| 8.6.1<br>DOR.ICT.NWS.FWF.008 | <p>The recertification must be performed in accordance with the established classification and the overall risk profile of ICT Systems involved.</p> <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware</p> <p><b>Key References:</b> DORA RTS RMF A.13.1h</p>                           |
| 8.6.2<br>DOR.ICT.NWS.FWF.009 | <p>For ICT Systems supporting critical or important functions, the adequacy of existing firewall rules and connection filters must be recertified at least every 6 months.</p> <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, End User Device, Mobile Device, Processing Peripheral, Other Device, Storage, Server &amp; Host Hardware</p> <p><b>Key References:</b> DORA RTS RMF A.13.1h</p> |
| 8.7<br>DOR.ICT.NWS.FWF.010   | <p>All requests - including the justification for the firewall rule - must be documented (to ensure traceability).</p> <p><b>Asset-Types:</b> Information, Business Process</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                              |
| 8.8<br>DOR.ICT.NWS.FWF.011   | <p>Deviations from the Network Adequacy Matrix must be approved.</p> <p><b>Asset-Types:</b> Information, Business Process</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                                                                |
| 8.9<br>DOR.ICT.NWS.FWF.012   | <p>Web-application firewalls must be installed in front of internet-facing web-based applications.</p> <p><b>Asset-Types:</b> Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Storage</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                            |
| 8.10<br>DOR.ICT.NWS.FWF.013  | <p>The desktop firewall and/or application firewall must ensure that only authorized traffic enters or leaves the ICT System.</p> <p><b>Asset-Types:</b> Information, Business Process, End User Device</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                  |

|                          |                                                                                                                      |
|--------------------------|----------------------------------------------------------------------------------------------------------------------|
| ID: 9<br>(version 2.0)   | Protection of perimeters                                                                                             |
| 9<br>DOR.ICT.NWS.PER.001 | It must be ensured that perimeters are secured in such a way that unauthorized access and connections are prevented. |

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 9.1<br>DOR.ICT.NWS.PER.002 | <p>Protective mechanisms must be implemented at each network security zone transition.</p> <p><b>Asset-Types:</b> Business Process, Cloud PaaS<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                                                                            |
| 9.2<br>DOR.ICT.NWS.PER.003 | <p>Only necessary and allowed connectivity (according to applicable Security Documentation (SD) /Network Adequacy Matrix) between network security zones must be implemented.</p> <p><b>Asset-Types:</b> Business Process, Cloud PaaS<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                     |
| 9.3<br>DOR.ICT.NWS.PER.004 | <p>All inbound and outbound network traffic must be controlled, monitored based on the confidentiality class of the IT Assets, and denied by default by the principle of explicit allowance.</p> <p><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS, Network Connection<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                              |
| 9.4<br>DOR.ICT.NWS.PER.005 | <p>IDS and IPS must be in place to analyze all network traffic between network security zones to ensure that attacks or misuse are actively prevented.</p> <p><b>Asset-Types:</b> Information, Business Process, Network Connection<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.7</p>                                                                                                                                                                                                                                                                        |
| 9.5<br>DOR.ICT.NWS.PER.006 | <p>IDS and IPS must be updated at defined intervals on a risk-based approach.</p> <p><b>Asset-Types:</b> Information, Business Process, Network Connection<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                                                                                                |
| 9.6<br>DOR.ICT.NWS.PER.007 | <p>Risk-based technical security measures must be implemented that are capable of detecting and responding to network-based attacks based on anomalous input or output traffic patterns and/or distributed denial of service (DDoS) and denial of service (DoS), including corresponding filtering capabilities.</p> <p><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, SaaS, Cloud Appliance, Cloud PaaS, Server &amp; Host Hardware, Network Connection, Supplier<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p> |
| 9.7<br>DOR.ICT.NWS.PER.008 | <p>When using cloud services, the CSP must allow for controls to minimize and protect the perimeter of Publicly Accessible Endpoints.</p> <p><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                         |
| 9.8<br>DOR.ICT.NWS.PER.009 | <p>It must be ensured that no network traffic could bypass perimeter security (e.g. firewalls, SDN). The protection used at the perimeter must be stateful.</p> <p><b>Asset-Types:</b> Business Process, Cloud Appliance, Cloud PaaS<br/> <b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22</p>                                                                                                                                                                                                                                                                      |

| ID: 10 (version 2.0)             | Web filtering                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>10</b><br>DOR.ICT.NWS.WEB.001 | <b>It must be ensured that suitable web filtering is in place to prevent access to unauthorized or insecure resources.</b>                                                                                                                                                                                                                                                                                                                                                                                                                             |
| 10.1<br>DOR.ICT.NWS.WEB.002      | Proxies must check all unencrypted and encrypted communications. To do this, for all encrypted connections between external and internal networks, interception and inspection must be possible at the proxy, in both directions.<br><br><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                                 |
| 10.2<br>DOR.ICT.NWS.WEB.003      | The management of blacklisted (denied) or whitelisted (allowed) destinations on proxies must be defined.<br><br><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                                                                                                                                                          |
| 10.3<br>DOR.ICT.NWS.WEB.004      | Proxies must be able to protect from prohibited targets, detect malware and protect users and ICT systems from malicious content.<br><br><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                                                                                                                                 |
| 10.4<br>DOR.ICT.NWS.WEB.005      | Bypassing the proxies must be prevented by appropriate configuration.<br><br><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                                                                                                                                                                                             |
| 10.5<br>DOR.ICT.NWS.WEB.006      | All proxy rules, including exceptions (whitelisting), must be revalidated at defined intervals.<br><br><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                                                                                                                                                                   |
| 10.6<br>DOR.ICT.NWS.WEB.007      | Access to external websites must be managed based on defined processes for website white- and blacklisting, covering the following aspects: <ul style="list-style-type: none"> <li>- Roles and responsibilities</li> <li>- Baseline of proxy rules</li> <li>- Management of exceptional approvals process</li> <li>- Management of proxy rule recertifications at defined intervals</li> <li>- Monitoring activities</li> </ul><br><b>Asset-Types:</b> Business Process, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.23 |
| 10.7<br>DOR.ICT.NWS.WEB.008      | Access to the following types of websites must be blocked: <ul style="list-style-type: none"> <li>- Known or suspected malicious websites</li> <li>- Command and control servers</li> <li>- Malicious websites acquired from threat intelligence</li> <li>- Websites sharing illegal content</li> </ul>                                                                                                                                                                                                                                                |

|                             |                                                                                                                                                                                                                                                                                                                        |
|-----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | <b>Asset-Types:</b> Business Process, End User Device, Mobile Device, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.23                                                                                                                                                                    |
| 10.8<br>DOR.ICT.NWS.WEB.009 | Websites that have an information upload function unless permitted for valid business reasons must be blocked following a risk-based approach.<br><br><b>Asset-Types:</b> Information, Business Process, End User Device, Mobile Device, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.23 |

| ID: 11 (version 2.0)        | Event logging                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 11<br>DOR.ICT.NWS.LOG.001   | <b>For network and cloud-related events, event logging must be established so that security-related events are logged and made available for later analysis.</b>                                                                                                                                                                                                                                                                                                 |
| 11.1<br>DOR.ICT.NWS.LOG.002 | Access to networks and network services must be logged and regularly evaluated for anomalies/attack scenarios.<br><br><b>Asset-Types:</b> Information, Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Software Appliance, Hardware Appliance, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15                                                       |
| 11.2<br>DOR.ICT.NWS.LOG.003 | Log management must be implemented to ensure that all security-relevant logs of IT Assets managed by Legal entity are persisted in a central space.<br><br><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.32                                                                                                                                                       |
| 11.3<br>DOR.ICT.NWS.LOG.004 | At least the following events must be logged and reported to SIEM or equivalent or network performance monitoring solution at the legal entity in accordance with the ICT Incident & Operational Event Management Guideline: <ul style="list-style-type: none"> <li>- Network traffic activities</li> <li>- Network performance</li> </ul> <b>Asset-Types:</b> Business Process, Cloud PaaS, Network Connection<br><b>Key References:</b> DORA RTS RMF A.12.2c.v |
| 11.4<br>DOR.ICT.NWS.LOG.005 | Unauthorized attempts to access the legal entity network must be banned, monitored, investigated, and reported to SIEM or equivalent at the legal entity.<br><br><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Cloud Appliance, Cloud PaaS, Network Connection<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.15                                                                                                             |

| ID: 12 (version 2.0)             | Security concept <sup>5</sup>                                                                                                                                                                                                                                                                                                                                                |
|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>12</b><br>DOR.ICT.NWS.DOC.001 | <b>It must be ensured that a security concept is in place, maintained and submitted to the Bundesnetzagentur in relevant cases.</b>                                                                                                                                                                                                                                          |
| 12.1<br>DOR.ICT.NWS.DOC.002      | A security concept which describes the threats and implemented security measures for the telecommunication network and/or offered telecommunication services and regularly verify their effectiveness must be created and maintained.<br><br><b>Asset-Types:</b> Business Process, Tool, Certificate, Cloud PaaS, Network Connection<br><b>Key References:</b> TKG §165, 166 |
| 12.2<br>DOR.ICT.NWS.DOC.003      | The security concept must be submitted to the Bundesnetzagentur when starting the operation and in case of significant changes.<br><br><b>Asset-Types:</b> Business Process<br><b>Key References:</b> TKG §166                                                                                                                                                               |

| ID: 13 (version 2.0)             | Cloud-specific requirements                                                                                                                                                                                                                                                                                                                                                                    |
|----------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>13</b><br>DOR.ICT.NWS.CLD.001 | <b>It must be ensured that robust cloud-specific security measures are in place.</b>                                                                                                                                                                                                                                                                                                           |
| 13.1<br>DOR.ICT.NWS.CLD.002      | It must be ensured that appropriate controls to ensure isolation of tenants are implemented.<br><br><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22                                                                                                                                            |
| 13.2<br>DOR.ICT.NWS.CLD.003      | Services of CSPs must be evaluated and tested, and it must be ensured that the services, including APIs, can be used to retrieve own data <sup>6</sup> .<br><br><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud PaaS<br><b>Key References:</b> ISO 27001:2022 Cor 202203                                                                                                        |
| 13.3<br>DOR.ICT.NWS.CLD.004      | The legal entity must ensure that provisions included in the contract with the CSP to access the data upon termination of the contract, to download all relevant data, and to permanently delete the data upon request by legal entity.<br><br><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS<br><b>Key References:</b> ISO 27001:2022 Cor 202203 A.8.22 |
| 13.4<br>DOR.ICT.NWS.CLD.005      | Transfer legal entity information/data to storage provided by cloud infrastructure is allowed only for authorized and approved suppliers. Other control requirements for suppliers are incorporated in the Third-Party ICT                                                                                                                                                                     |

<sup>5</sup> The term originates from the German Telecommunications Act (Telekommunikationsgesetz), in which the term "Sicherheitskonzept" is used and has been translated into English.

<sup>6</sup> By "own" data, data from other LEs is also meant where relevant.

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | <p>Risk Management Guideline. Measures must be implemented to prevent and detect the use of such non-authorized and non-approved suppliers.</p> <p><b>Asset-Types:</b> Information, Business Process, SaaS, Cloud Appliance, Cloud PaaS</p> <p><b>Key References:</b> ISO 27001:2022 Cor 202203 A.5.10</p>                                                                                                                                                                                                                                                              |
| 13.5<br>DOR.ICT.NWS.CLD.006 | <p>It must be ensured host and guest OS, hypervisor or infrastructure control plane are hardened according to their respective industry best practices, and supported by technical controls, as part of a security baseline.</p> <p><b>Asset-Types:</b> Business Process, Cloud Appliance, Operating System, Cloud PaaS</p> <p><b>Key References:</b> CCM requirement IVS04</p>                                                                                                                                                                                         |
| 13.6<br>DOR.ICT.NWS.CLD.007 | <p>Application and infrastructure architecture must be set up in such a way that intrusion or expansion of unauthorized access is made as difficult as possible.</p> <p><b>Asset-Types:</b> Business Process, Commercial-off-the-Shelf Solution, Underlying Software/Technology, SaaS, Tool, Certificate, Software Appliance, Hardware Appliance, Cloud Appliance, Operating System, Cloud PaaS, Container, Storage, Server &amp; Host Hardware, Network Connection</p> <p><b>Key References:</b> BaFin Aufsichtsmitteilung zu Auslagerungen an Cloud Anbieter IV.2</p> |
| 13.7<br>DOR.ICT.NWS.CLD.008 | <p>As part of ensuring an adequate level of cyber and information security, measures must be taken to secure network connections against disruption and unauthorized monitoring.</p> <p><b>Asset-Types:</b> Information, Business Process, Cloud Appliance, Cloud PaaS, Network Connection</p> <p><b>Key References:</b> BaFin Aufsichtsmitteilung zu Auslagerungen an Cloud Anbieter IV.2</p>                                                                                                                                                                          |

## 5. Roles and Responsibilities

### 5.1. Creator

The creator of the Network Security Guideline is the ICT Risk Governance & Advisory Unit (Specialist).

The creator of the Network Security Guideline has the responsibility to issue clear, precise, and appropriate written rules to give guidance for implementation to the target group. It is important to ensure that all required information is accurate, up to date and complete.

### 5.2. Guideline Owner

The owner of the Network Security Guideline is Head of ICT Risk Governance & Advisory Unit.

The most important tasks (not an exhaustive list) within the scope of responsibility are:

- Ensure completeness of the Guideline within functional area of responsibility
- Ensure correctness of content and the Guideline is up to date
- Define and conduct adherence oversight measures for Guidelines on a regular basis
- Assess impact on the Guideline with major focus on requirements as well as roles and responsibilities in the event of organizational changes, new products etc.

The Guideline Owner has at least an Expert or Head of Unit level.

The Guideline Owner is responsible for publishing and updating the Network Security Guideline according to established procedures within the organization.

## 6. Appendix

### 6.1. Contact Information

**Written Rule Owner:** Head of ICT Risk Governance & Advisory Unit

Please contact ICT Risk Governance & Advisory in case of any questions related to this Guideline.

### 6.2. Document History

#### Document History

| Version | Date       | Changes & Background                |
|---------|------------|-------------------------------------|
| 1.0     | 17.01.2025 | Initial set-up of this Guideline    |
| 1.1     | 15.08.2025 | Annual Update Guideline             |
| 2.0     | 19.08.2026 | Annual update with material changes |

#### Coordination before publication

| Version | Date       | Task                        | Name                                                     |
|---------|------------|-----------------------------|----------------------------------------------------------|
| 2.0     | 15.05.2026 | <b>Creator</b>              | ICT Risk Governance & Advisory Unit (Specialist)         |
|         | 28.07.2026 | <b>Content Review</b>       | LE CISOs<br>TISOs<br>IT Ameli project                    |
|         | 28.07.2026 | <b>Content Confirmation</b> | Head of ICT Risk Governance & Advisory Unit and LE CISOs |

#### Approvals

| Version | Date       | Task            | Name                    |
|---------|------------|-----------------|-------------------------|
| 2.0     | 13.08.2026 | <b>Approval</b> | DBAG Chief Risk Officer |

### 6.3. Related Written Rules

|                              |                                                                              |
|------------------------------|------------------------------------------------------------------------------|
| Superordinated Written Rules | <ul style="list-style-type: none"> <li>ICT Risk Management Policy</li> </ul> |
| Subordinated Written Rules   | <ul style="list-style-type: none"> <li>n/a</li> </ul>                        |

## 6.4. Abbreviations

The abbreviations in this document are defined in the overall ICT Risk Glossary, which is provided on the Intranet website.

**\*\*\* END OF DOCUMENT \*\*\***

---